Alen Da Luz

Proof of Concept e risultati

11/10/2026

DESCRIZIONE: Quarto e ultimo report del progetto finale, descrive la Proof of Concept: una catena di attacco realistica condotta da Kali Linux (ricognizione, enumerazione, brute force, scansione porte, denial of service) e il relativo rilevamento. Dimostra come il SIEM rilevi gli attacchi di autenticazione e di scansione, evidenzia il limite della telemetria endpoint sugli attacchi volumetrici, e mostra come un IDS di rete (Suricata) colmi quel limite

1. Preparazione della PoC

La macchina attaccante è una VM Kali Linux con IP 192.168.1.30, sulla stessa rete dei bersagli (scenario di minaccia interna), la fase di denial of service è stata eseguita in rete isolata per non impattare la rete reale, per gli attacchi alle credenziali è stato preparato un dizionario di password comuni estratto da rockyou (prime 50 voci)

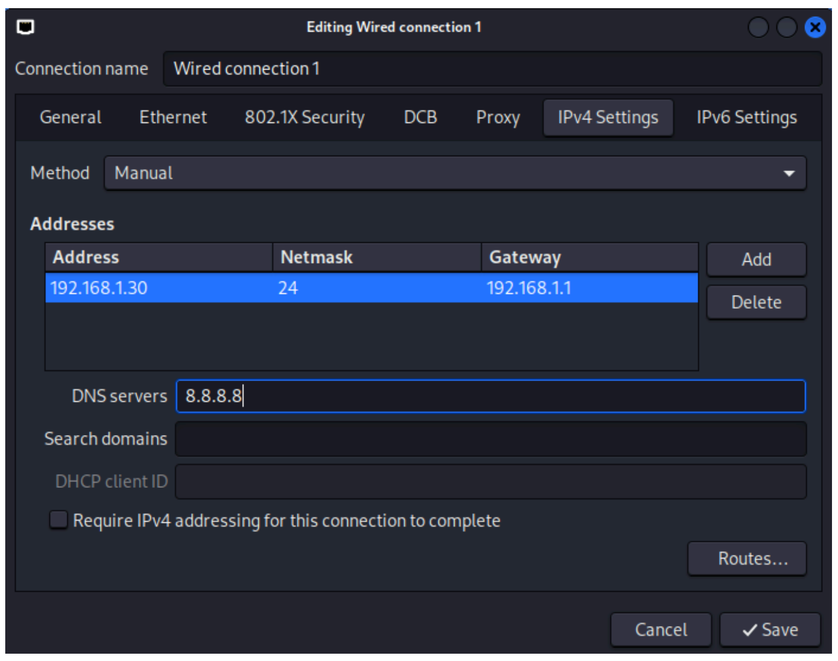


Fig. 1 — Configurazione di rete della macchina attaccante Kali (IP statico 192.168.1.30)

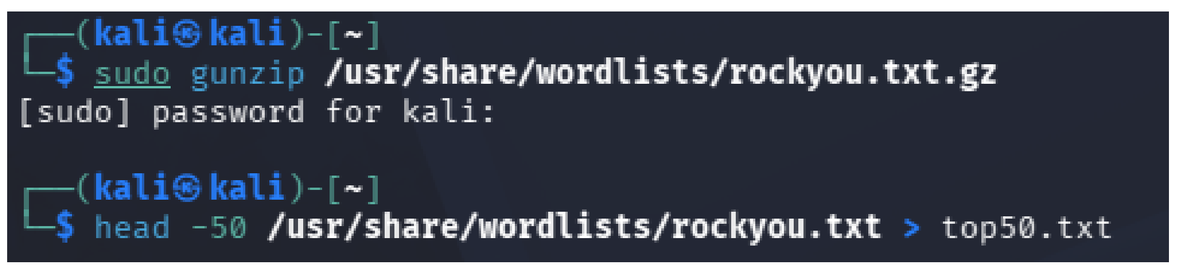


Fig. 2 — Preparazione del dizionario di password (top50.txt) a partire da rockyou

2. Ricognizione (reconnaissance)

L'attaccante individua gli host attivi sulla sottorete, poi identifica i servizi per capire il ruolo di ciascuna macchina e scegliere il bersaglio di maggior valore

2.1 — Scoperta degli host

Una scansione di tipo host discovery (nmap -sn) elenca gli indirizzi IP attivi sulla rete 192.168.1.0/24. Il risultato fornisce IP e MAC address, ma non il ruolo degli host: quello va dedotto interrogando i servizi

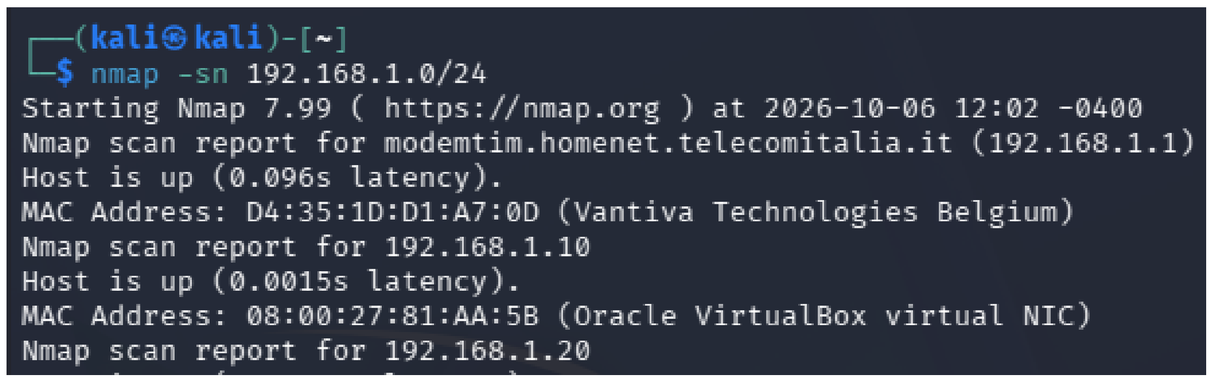


Fig. 3 — Host discovery sulla sottorete: elenco degli indirizzi IP attivi

2.2 — Identificazione del Domain Controller

Scansionando i servizi degli host, il Domain Controller si rivela dalla combinazione di porte caratteristiche: Kerberos (88), LDAP (389), DNS (53) e Global Catalog (3268), nessuna workstation espone questa terna: è così che l'attaccante identifica il bersaglio. L'interrogazione del servizio LDAP (rootDSE) rivela inoltre il nome del dominio

```
Nmap scan report for 192.168.1.10
Host is up (0.0013s latency).
Not shown: 988 filtered tcp ports (no-response)
PORT     STATE SERVICE
53/tcp   open  domain
88/tcp   open  kerberos-sec
135/tcp  open  msrpc
139/tcp  open  netbios-ssn
389/tcp  open  ldap
445/tcp  open  microsoft-ds
464/tcp  open  kpasswd5
593/tcp  open  http-rpc-epmap
636/tcp  open  ldapssl
3268/tcp open  globalcatLDAP
3269/tcp open  globalcatLDAPssl
5985/tcp open  wsman
MAC Address: 08:00:27:81:AA:5B (Oracle VirtualBox virtual NIC)
```

Fig. 4 — Scansione dei servizi dell'host 192.168.1.10: porte tipiche di un Domain Controller (Kerberos, LDAP, DNS, Global Catalog)

```
┌──(kali㉿kali)-[~]
└─$ nmap -Pn -p 389 --script ldap-rootdse 192.168.1.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-06 13:21 -0400
Nmap scan report for 192.168.1.10
Host is up (0.00057s latency).

PORT    STATE SERVICE
389/tcp open  ldap
| ldap-rootdse:
| LDAP Results
|   <ROOT>
|       domainFunctionality: 7
|       forestFunctionality: 7
|       domainControllerFunctionality: 7
|       rootDomainNamingContext: DC=Lab,DC=local
|       ldapServiceName: Lab.local:dc01$@LAB.LOCAL
```

Fig. 5 — Interrogazione del rootDSE via LDAP: il naming context rivela il dominio lab.local

3. Enumerazione degli utenti

Individuato il DC, l'attaccante cerca account validi da attaccare, l'enumerazione anonima via SMB restituisce solo gli account predefiniti di Active Directory e viene respinta sulla lista utenti completa (NT_STATUS_ACCESS_DENIED): il DC non divulga gli account personalizzati a utenti non autenticati, comportamento corretto

```
┌──(kali㉿kali)-[~]
└─$ enum4linux -U 192.168.1.10
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Oct  6 13:06:22 2026

 ==========( Target Information )==========

Target ........... 192.168.1.10
RID Range ........ 500-550,1000-1050
Username ......... ''
Password ......... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

 ==========( Enumerating Workgroup/Domain on 192.168.1.10 )==========

[+] Got domain/workgroup name: LAB

 ==========( Session Check on 192.168.1.10 )==========

[+] Server 192.168.1.10 allows sessions using username '', password ''

 ==========( Getting domain SID for 192.168.1.10 )==========

Domain Name: LAB
Domain Sid: S-1-5-21-1423581411-1082456030-1479303975

[+] Host is part of a domain (not a workgroup)

 ==========( Users on 192.168.1.10 )==========

[E] Couldn't find users using querydispinfo: NT_STATUS_ACCESS_DENIED

[E] Couldn't find users using enumdomusers: NT_STATUS_ACCESS_DENIED
```

Fig. 6 — Enumerazione SMB (enum4linux): account predefiniti noti, ma accesso negato alla lista utenti completa

Bloccata la via SMB, l'attaccante ripiega sull'enumerazione via Kerberos (kerbrute): si testa una lista di nomi utente plausibili, costruiti su convenzioni comuni (nome, nome.cognome), e il servizio Kerberos conferma quali esistono realmente, dalla lista emergono due account validi: administrator e mariorossi

```
┌──(kali㉿kali)-[~]
└─$ cat utenti.txt
administrator
lucabianchi
giuseppeverdi
francescorusso
annaferrari
mariorossi
giovanniesposito
paoloromano
federicagialli
```

Fig. 7 — Lista di username candidati, costruita su convenzioni comuni

```
┌──(kali㉿kali)-[~]
└─$ kerbrute userenum -d lab.local --dc 192.168.1.10 utenti.txt

    __             __               __
   / /_____  _____/ /_  _______  __/ /____
  / //_/ _ \/ ___/ __ \/ ___/ / / / __/ _ \
 / ,< /  __/ /  / /_/ / /  / /_/ / /_/  __/
/_/|_|\___/_/  /_.___/_/   \__,_/\__/\___/

Version: v1.0.3 (9dad6e1) - 10/06/26 - Ronnie Flathers @ropnop

2026/10/06 13:43:53 >  Using KDC(s):
2026/10/06 13:43:53 >   192.168.1.10:88

2026/10/06 13:43:53 >  [+] VALID USERNAME:       administrator@lab.local
2026/10/06 13:43:53 >  [+] VALID USERNAME:       mariorossi@lab.local
2026/10/06 13:43:53 >  Done! Tested 9 usernames (2 valid) in 0.011 seconds
```

Fig. 8 — Enumerazione Kerberos (kerbrute): confermati come validi gli account administrator e mariorossi

4. Attacco alle credenziali (brute force)

Sugli account scoperti è stato lanciato un attacco a dizionario via SMB, senza conoscere le password (attacco cieco)

```
┌──(kali㉿kali)-[~]
└─$ nxc smb 192.168.1.10 -u mariorossi -p top50.txt
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Creating missing folder logs/sam
[*] Creating missing folder logs/lsa
[*] Creating missing folder logs/ntds
[*] Creating missing folder logs/dpapi
[*] Creating default workspace
[*] Initializing VNC protocol database
[*] Initializing SSH protocol database
[*] Initializing WINRM protocol database
[*] Initializing RDP protocol database
[*] Initializing SMB protocol database
[*] Initializing WMI protocol database
[*] Initializing LDAP protocol database
[*] Initializing FTP protocol database
[*] Initializing NFS protocol database
[*] Initializing MSSQL protocol database
[*] Copying default configuration file
SMB         192.168.1.10    445    DC01            [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:Lab.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:123456 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:12345 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:123456789 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:password STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:iloveyou STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:princess STATUS_ACCOUNT_LOCKED_OUT
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:1234567 STATUS_ACCOUNT_LOCKED_OUT
SMB         192.168.1.10    445    DC01            [-] Lab.local\mariorossi:rockyou STATUS_ACCOUNT_LOCKED_OUT
```

Fig. 9 — Brute force su mariorossi: dopo pochi tentativi l'account viene bloccato (STATUS_ACCOUNT_LOCKED_OUT) dalla policy

```
┌──(kali㉿kali)-[~]
└─$ nxc smb 192.168.1.10 -u administrator -p top50.txt
SMB         192.168.1.10    445    DC01            [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:Lab.local) (signing:True) (SMBv1:None) (Null Auth:True)
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:123456 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:12345 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:123456789 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:password STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:iloveyou STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:princess STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:1234567 STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:rockyou STATUS_LOGON_FAILURE
SMB         192.168.1.10    445    DC01            [-] Lab.local\administrator:12345678 STATUS_LOGON_FAILURE
```

Fig. 10 — Brute force su administrator: tentativi ripetuti falliti (STATUS_LOGON_FAILURE), attacco non andato a segno

Ogni tentativo genera un evento 4625 sul Domain Controller, che il SIEM riceve con i campi estratti: account bersaglio e IP sorgente (192.168.1.30, cioè Kali), questo conferma la piena visibilità del SIEM sull'attacco di autenticazione

```
<Event xmlns='http://schemas.microsoft.com/win/2004/08/events/event'><System><Provider Name='Microsoft-Windows-Security-Auditing' Guid='{54849625-5478-4994-a5ba-3e3b0328c30d}'/><EventID>
625</EventID><Version>0</Version><Level>0</Level><Task>12544</Task><Opcode>0</Opcode><Keywords>0x8010000000000000</Keywords><TimeCreated SystemTime='2026-10-08T17:59:41.1358890Z'/><Event
ecordID>10415</EventRecordID><Correlation/><Execution ProcessID='644' ThreadID='700'/><Channel>Security</Channel><Computer>DC01.Lab.local</Computer><Security/></System><EventData><Data N
me='SubjectUserSid'>S-1-0-0</Data><Data Name='SubjectUserName'>-</Data><Data Name='SubjectDomainName'>-</Data><Data Name='SubjectLogonId'>0x0</Data><Data Name='TargetUserSid'>S-1-0-0</Da
a><Data Name='TargetUserName'>mariorossi</Data><Data Name='TargetDomainName'>Lab.local</Data><Data Name='Status'>0xc000006d</Data><Data Name='FailureReason'>%%2313</Data><Data Name='SubS
atus'>0xc000006a</Data><Data Name='LogonType'>3</Data><Data Name='LogonProcessName'>NtLmSsp </Data><Data Name='AuthenticationPackageName'>NTLM</Data><Data Name='WorkstationName'>-</Data>
Data Name='TransmittedServices'>-</Data><Data Name='LmPackageName'>-</Data><Data Name='KeyLength'>0</Data><Data Name='ProcessId'>0x0</Data><Data Name='ProcessName'>-</Data><Data Name='Ip
ddress'>192.168.1.30</Data><Data Name='IpPort'>49604</Data></EventData></Event>

host = DC01 | source = XmlWinEventLog:Security | sourcetype = XmlWinEventLog
```

Fig. 11 — Evento 4625 ricevuto dal SIEM in formato XML: TargetUserName mariorossi, IpAddress 192.168.1.30

```
index=windows host="DC01" source="XmlWinEventLog:Security" EventCode=4625 TargetUserName="administrator" | stats count by IpAddress
```

✓ **50 eventi** (08/10/26 19:48:00.000 - 08/10/26 23:48:13.000) Nessun campionamento degli eventi

Eventi | Pattern | **Statistiche (1)** | Visualizzazione

Mostra: 20 per pagina | Formato | Anteprima: on

IpAddress
192.168.1.30

Fig. 12 — Ricerca in Splunk: gli accessi falliti su administrator provengono tutti dall'IP 192.168.1.30 (Kali)

5. Rilevamento nel SIEM

Gli attacchi hanno attivato le regole di correlazione in tempo reale. La lista degli allarmi scattati mostra sia i Brute Force sia l'Account Lockout; la ricerca sull'evento 4740 conferma il blocco dell'account administrator

Ora ↓	Nome allarme	App	Tipo	Severità	Moda
2026-10-08 23:46:15 CEST	Brute Force - Accessi Falliti	search	In tempo reale	Media	Per Result
2026-10-08 23:46:14 CEST	Account Lockout - Blocco Account	search	In tempo reale	Media	Per Result
2026-10-08 23:46:14 CEST	Brute Force - Accessi Falliti	search	In tempo reale	Media	Per Result
2026-10-08 23:46:14 CEST	Brute Force - Accessi Falliti	search	In tempo reale	Media	Per Result

Fig. 13 — Allarmi scattati durante l'attacco al Domain Controller: più alert Brute Force e un alert Account Lockout

Ora ↓	Nome allarme	App	Tipo	Severità	Moda
2026-10-08 21:03:09 UTC	Account Lockout - Blocco Account	search	In tempo reale	Media	Per Result

Fig. 14 — Alert Account Lockout attivato in tempo reale

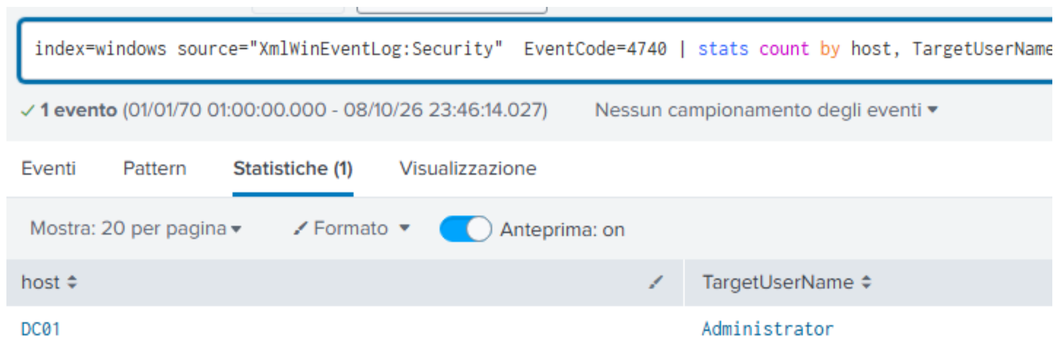


Fig. 15 — Ricerca SPL sull'evento 4740: conferma del blocco dell'account administrator sul Domain Controller

Anche la scansione delle porte è stata rilevata: la telemetria di rete di Sysmon mostra l'IP 192.168.1.30 che contatta un elevato numero di porte diverse del DC, attivando la regola Port Scan

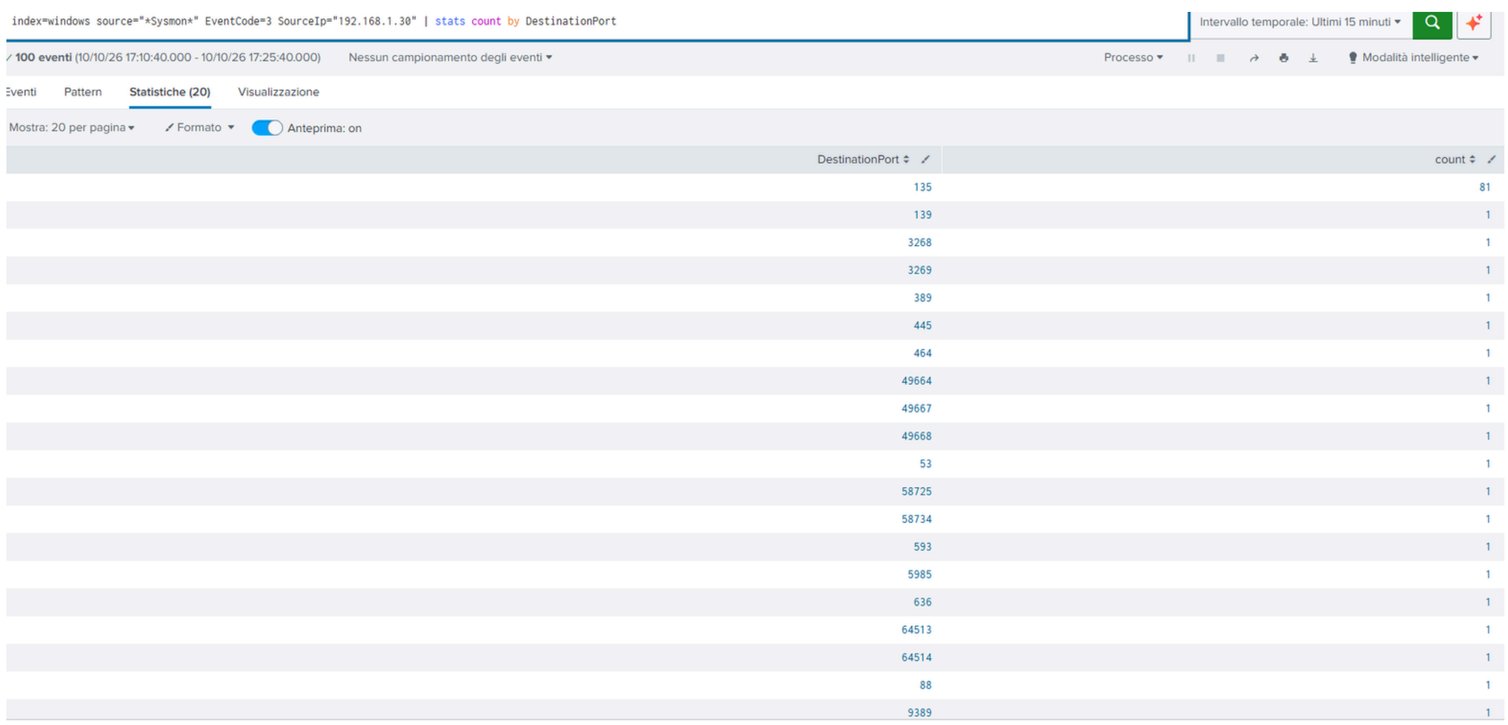


Fig. 16 — Rilevamento della scansione nel SIEM: l'IP 192.168.1.30 contatta numerose porte del Domain Controller

5.1 Rilevamento dei Pannelli

A conferma del rilevamento, la dashboard di monitoraggio costruita nel Report 3 si popola in tempo reale durante gli attacchi, offrendo una visione d'insieme immediata dell'attività malevola. Nei pannelli si vede l'andamento temporale che evidenzia i picchi di accessi falliti in corrispondenza del Brute Force; gli account presi di mira sono administrator (50 tentativi) e mariorossi (5 tentativi); l'unico IP sorgente è 192.168.1.30 (la macchina attaccante kali) con 55 tentativi; la tabella che conferma il blocco degli account administrator e mariorossi sul Domain Controller; il totale degli accessi falliti rilevati che è 55

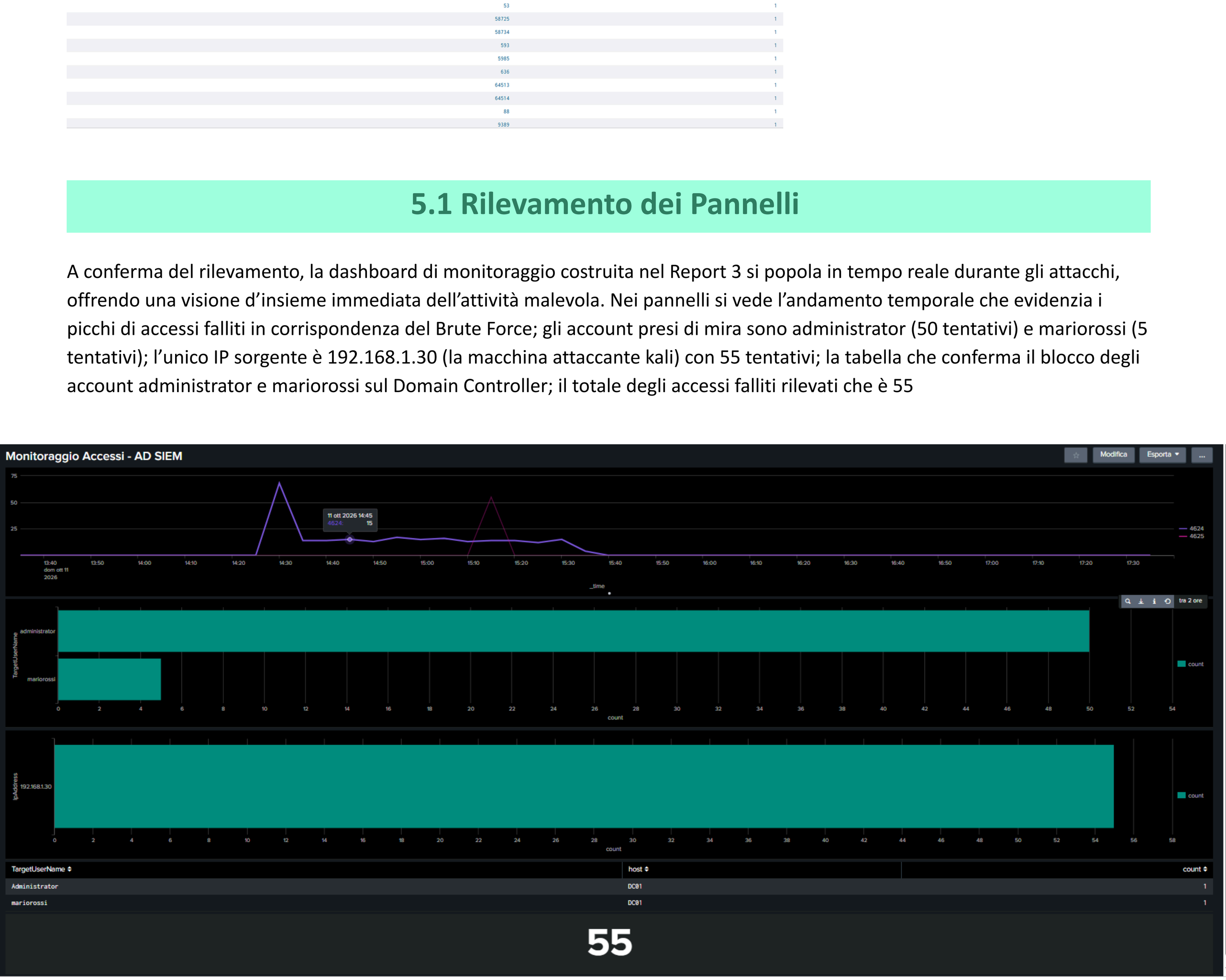


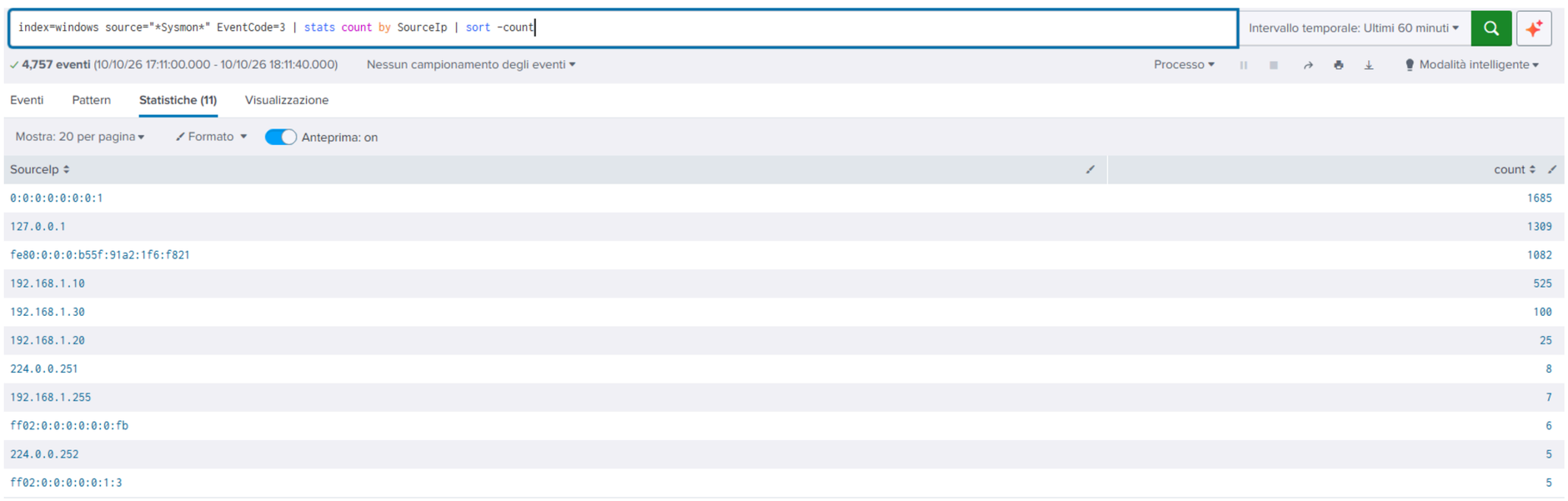
Fig. 17 — Dashboard "monitoraggio Accessi - AD SIEM" popolata durante gli attacchi

6. Denial of Service e limite del SIEM

È stato infine eseguito un attacco SYN flood verso la porta SMB del Domain Controller, qui emerge un punto chiave: Sysmon registra le connessioni stabilite, ma un SYN flood invia pacchetti SYN senza completare la connessione, il SIEM endpoint vede quindi solo una frazione minima del traffico (poche decine di connessioni a fronte di migliaia di pacchetti), insufficiente a qualificare l'attacco

```
┌──(kali㉿kali)-[~]
└─$ sudo hping3 -S --flood -p 445 192.168.1.10
HPING 192.168.1.10 (eth0 192.168.1.10): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

Fig. 18 — Attacco SYN flood in corso da Kali verso il Domain Controller (hping3, flood mode)



SourceIp	count
0:0:0:0:0:0:0:1	1685
127.0.0.1	1309
fe80:0:0:0:b55f:91a2:1f6:f821	1082
192.168.1.10	525
192.168.1.30	100
192.168.1.20	25
224.0.0.251	8
192.168.1.255	7
ff02:0:0:0:0:0:0:fb	6
224.0.0.252	5
ff02:0:0:0:0:0:1:3	5

Fig. 19 — Nel SIEM il flood lascia solo una traccia limitata: la telemetria endpoint non coglie l'attacco volumetrico

Per catturare realmente l'attacco è stato usato uno sniffer di rete (Wireshark), che opera a livello di pacchetti: filtrando i SYN verso il DC si vede la raffica del flood, prova diretta dell'attacco volumetrico

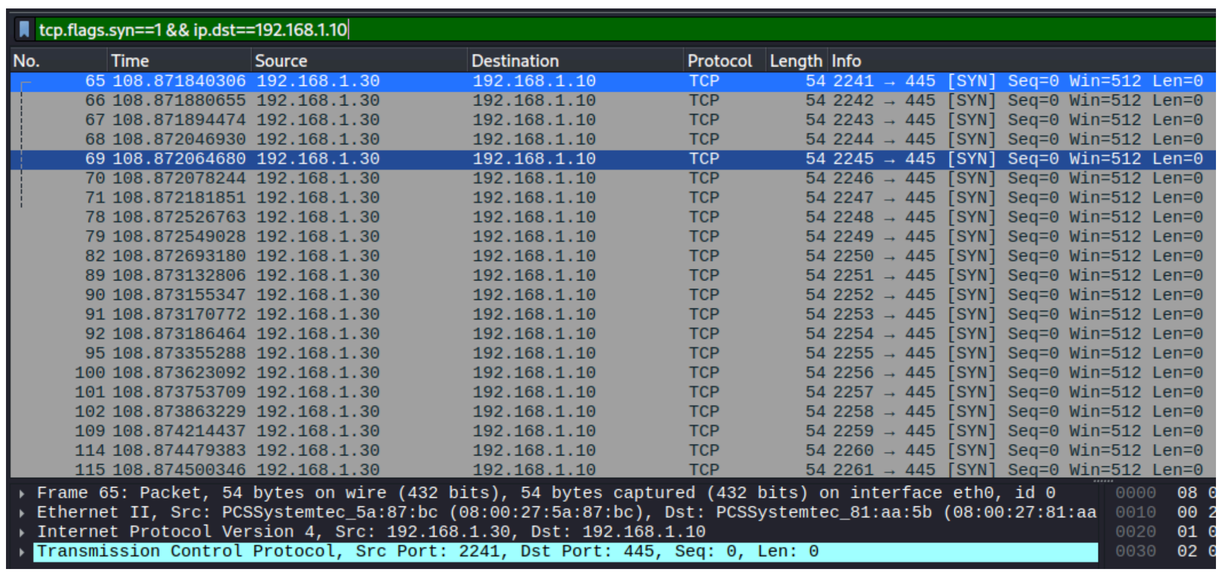


Fig. 20 — Cattura con Wireshark: raffica di pacchetti SYN da 192.168.1.30 verso 192.168.1.10:445 (il flood)

7. IDS di rete (Suricata)

Per rilevare automaticamente ciò che il SIEM endpoint non vede, è stato installato un IDS di rete (Suricata) sul Domain Controller, con una regola personalizzata. Una regola IDS si definisce in un file di regole e descrive un pattern di traffico: la prima rileva un numero elevato di pacchetti SYN verso porte diverse (port scan), la seconda un volume anomalo di SYN verso la porta 445 (SYN flood). Il parametro di soglia (threshold) distingue il traffico normale dall'attacco

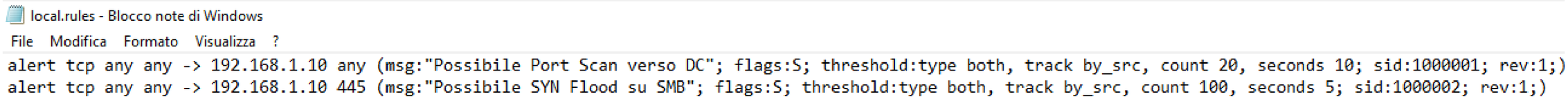


Fig. 21 — Regola personalizzata dell'IDS (local.rules): rilevamento di port scan e SYN flood verso il Domain Controller

Rilanciati gli attacchi in rete isolata, l'IDS li ha rilevati entrambi, registrando gli allarmi nel proprio log: più occorrenze di "Possibile Port Scan verso DC" e il "Possibile SYN Flood su SMB" che il SIEM endpoint non coglieva

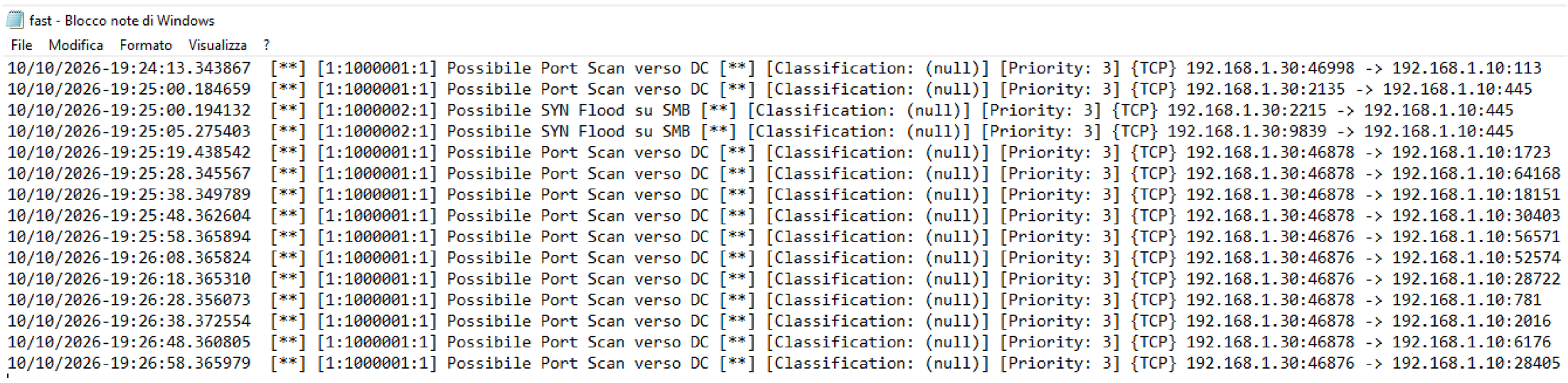


Fig. 22 — Log dell'IDS (fast.log): rilevamento del port scan e del SYN flood provenienti da 192.168.1.30

8. Conclusioni e risultati

La Proof of Concept ha dimostrato una catena di attacco completa e il suo rilevamento a più livelli. Il quadro di sintesi:

Attacco	Rilevato dal SIEM (endpoint)	Rilevato dall'IDS (rete)
Port scan	Sì (Sysmon EventCode 3)	Sì
Brute force	Sì (4625 + alert)	—
Blocco account	Sì (4740 + alert)	—
SYN flood (DoS)	No (solo traccia parziale)	Sì

Il progetto ha raggiunto l’obiettivo che si era posto: realizzare un laboratorio virtuale con un dominio Active Directory funzionante, monitorato da un SIEM, e dimostrare, attraverso una catena di attacco realistica, che il sistema è in grado di rilevare le minacce mentre si verificano. Tutti gli elementi richiesti sono stati implementati e verificati: il Domain Controller gestisce autenticazione e DNS del dominio; il Client è stato aggiunto al dominio ed è monitorato al pari del server; il SIEM raccoglie in modo centralizzato i log di entrambe le macchine; una macchina attaccante ha condotto attacchi dimostrativi che sono stati rilevati e, dove possibile, neutralizzati. Partendo da una posizione di totale assenza di informazioni, l’attaccante ha individuato gli host attivi, ha riconosciuto il Domain Controller deducendone il ruolo dai servizi esposti (Kerberos, LDAP, Global Catalog), ha scoperto il nome del dominio interrogando il servizio di directory e ha identificato account validi tramite enumerazione Kerberos, dopo che la via SMB era stata correttamente respinta dal server; su questi account ha quindi lanciato un attacco a dizionario.

Sul piano del rilevamento, i risultati confermano l’efficacia del monitoraggio costruito. Gli attacchi alle credenziali hanno generato gli eventi attesi (accessi falliti 4625 e blocco account 4740), completi dell’account bersaglio e dell’indirizzo IP della macchina attaccante; le regole di correlazione in tempo reale si sono attivate e la dashboard si è popolata istantaneamente, offrendo una visione d’insieme immediata dell’attività malevola, con administrator e mariorossi come bersagli e 192.168.1.30 come unica sorgente. La scansione delle porte è stata rilevata grazie alla telemetria di rete di Sysmon e altrettanto importante è stata la dimostrazione dell’efficacia della contromisura: la policy di blocco account ha fermato il brute force bloccando gli account presi di mira, trasformando un tentativo d’intrusione in un attacco fallito e tracciato.

Un risultato altrettanto significativo, perché spesso trascurato, è la scoperta di un limite. L’attacco volumetrico (SYN flood) è sfuggito quasi del tutto alla sorveglianza basata sui log degli endpoint: il SIEM ne ha colto solo una traccia marginale, perché questo tipo di telemetria registra le connessioni completate e non il flusso di pacchetti grezzi che caratterizza un denial of service, l’attacco è stato invece catturato pienamente dallo sniffer di rete e, soprattutto, rilevato automaticamente dall’IDS (Suricata) con una regola personalizzata. Questo dimostra concretamente che nessuno strumento è sufficiente da solo: la visibilità sull’endpoint e la visibilità sulla rete sono complementari, e una difesa efficace deve operare su entrambi i livelli. La coerenza temporale tra le sorgenti si è rivelata critica: un disallineamento dell’orologio del SIEM collocava gli eventi fuori dalle finestre di ricerca, rendendoli di fatto invisibili finché non è stata ripristinata la sincronizzazione. Infine, l’adozione di una convenzione prevedibile per i nomi utente ha reso l’account di test individuabile dall’enumerazione, a conferma di come anche scelte apparentemente innocue incidano sulla superficie d’attacco.

Vanno riconosciuti con onestà anche i limiti del laboratorio, dettati dalle risorse disponibili, la rete è piatta, con l’attaccante sullo stesso segmento dei bersagli: uno scenario di minaccia interna, valido e realistico, ma diverso da un attacco che provenga dall’esterno attraverso un perimetro difeso. L’IDS è stato installato sul nodo critico anziché su un gateway dedicato, e il monitoraggio ha riguardato un solo client. Nessuno di questi limiti intacca la validità dei meccanismi dimostrati ma ne delimita il contesto